SOFTWARE CHANGE IMPLEMENTATION REPORT

CR-026: Forgot Password Using Email OTP Verification

Field	Details
Change Request ID	CR-026
Change Request Title	Forgot Password Using Email OTP Verification
Student Name	K.Varshika
Student ID	JF/ICT/24/10
Implementation Status	Partially Implemented
Date	14 October 2026

1. Change Request Summary

1.1 Business Requirement

The Student Management System required a secure password recovery facility for students who forgot their account passwords. Previously, students could not complete password recovery through an email-based OTP verification process.

The purpose of CR-026 was to introduce a Forgot Password feature that allows students to verify their identity using a One-Time Password (OTP) sent to their registered email address. After successful verification, students should be able to create a new password and regain access to their accounts without administrator intervention.

The feature is intended to improve account accessibility, security, and usability.

1.2 Existing Behaviour

Before implementing CR-026:

- Students used the existing login page to access their accounts.
- Students who forgot their passwords required an appropriate password recovery mechanism.
- An email-based OTP verification workflow was not available or was not fully functional.
- Students needed a secure method to verify their identity before changing their passwords.
- The existing login and authentication functionality needed to remain operational.

1.3 Requested Change

A Forgot Password feature was required to support password recovery through email OTP verification.

The requested functionality includes:

- Provide a Forgot Password option on the login page.
- Allow students to enter their registered email address.
- Verify that the email address belongs to an eligible student account.
- Generate a six-digit OTP for password recovery.
- Send the OTP to the registered email address.
- Store the OTP as a secure hash rather than storing the plain OTP.
- Set an OTP expiry period of 10 minutes.
- Allow students to submit the OTP for verification.
- Reject invalid, expired, or previously used OTPs.
- Allow students to enter and confirm a new password after successful OTP verification.
- Validate the new password and confirmation before updating the account.
- Store the new password using the existing password-hashing mechanism.
- Mark the OTP as used after successful completion of the recovery process.
- Display appropriate success and error messages.
- Preserve existing login, authentication, and student management functionality.
- Prevent unauthorized password changes without successful OTP verification.

2. Implementation

2.1 Implementation Summary

CR-026 introduces an email-based password recovery workflow for the Student Management System.

The intended workflow consists of three main stages:

1. The student enters the registered email address on the Forgot Password page.
2. The system generates a six-digit OTP, stores its hash with an expiry time, and sends the OTP by email.
3. The student verifies the OTP and enters a new password with confirmation. After successful verification, the password is updated securely.

The backend uses Node.js and Express to process password recovery requests. MySQL stores the OTP recovery records, while Nodemailer is used to connect to the configured SMTP email service.

The `password_reset_otps` table has been created. The backend starts successfully on port 5000. However, the latest terminal output shows a Gmail SMTP authentication failure (`EAUTH / 535`). Therefore, successful OTP email delivery and end-to-end password recovery have not yet been verified.

2.2 Affected Files

File / Component	Change	Purpose
backend/src/controllers/authController.js	Modified	Handles password recovery, OTP generation, email delivery, OTP verification, and password reset.
backend/src/routes/authRoutes.js	Modified	Registers the authentication and password recovery endpoints.
backend/src/models/userModel.js	Verify whether modified	May contain user lookup or password update database operations, depending on the current implementation.
backend/.env	Modified / Configured	Stores SMTP connection settings, database configuration, and other environment variables.
backend/server.js	Existing / Verified	Starts the Express backend and loads environment configuration.
backend/src/app.js	Verify whether modified	Registers application routes and middleware if changes were required.
frontend/src/pages/LoginPage.jsx	Modified / Verify	Provides access to the Forgot Password workflow from the login page.
frontend/src/pages/ForgotPasswordPage.jsx	Added / Verify	Collects the student's registered email address and requests an OTP.
frontend/src/pages/ResetPasswordPage.jsx	Added / Verify	Provides OTP verification and new password submission.
frontend/src/routes/App.jsx	Modified / Verify	Registers the relevant frontend routes, if required by the current project structure.
password_reset_otps database table	Added	Stores hashed OTPs, expiry information, usage status, attempt count, and creation time.

Note: The final file list should be checked against the actual Git changes or project files before submission. Files marked “Verify” should only be reported as modified if they were actually changed.

2.3 Technical Changes

A. OTP Generation

The system generates a six-digit OTP when a password recovery request is submitted for an eligible student account.

The OTP is intended to be sent to the student's registered email address. It is used to verify that the person requesting the password reset has access to that email account.

B. Secure OTP Storage

The generated OTP is hashed using SHA-256 before being stored in the `password_reset_otps` table.

The table includes the following fields:

- `id` – Unique identifier for the OTP record.
- `user_id` – Identifier of the account associated with the OTP.
- `otp_hash` – Hashed OTP value.
- `expires_at` – Expiry date and time.
- `used_at` – Indicates when the OTP was used.
- `attempts` – Tracks verification attempts.
- `created_at` – Records when the OTP entry was created.

This design supports OTP verification, expiry checking, and one-time-use handling.

C. OTP Expiry and One-Time Use

The recovery process is designed to reject OTPs that have expired after 10 minutes.

After a successful password reset, the OTP should be marked as used so that it cannot be reused. The backend must validate the OTP status, expiry time, and verification result before allowing a password change.

D. Email Delivery Using SMTP

Nodemailer is used to send OTP emails through the configured SMTP service.

The current Gmail SMTP configuration uses the following settings:

Setting	Configuration

SMTP host	`smtp.gmail.com`
SMTP port	`587`
Secure connection option	`false` for STARTTLS
SMTP username	Configured through `SMTP_USER`
SMTP password	Configured through `SMTP_PASS`

The SMTP username and password are stored in environment variables rather than hardcoded into application source code.

Current issue: Gmail rejects the SMTP login with error `EAUTH`, response code `535`, and the message `Username and Password not accepted`. As a result, successful OTP email delivery is currently blocked.

E. Database Integration

The OTP recovery process uses the MySQL database associated with the Student Management System.

The `password_reset_otps` table has been created with the expected OTP-related columns.

During earlier testing, the backend also reported:

```
Unknown column 'email' in 'where clause'
```

This indicates that at least one earlier password recovery query referenced an email column that was not available in the queried table. In this project, student email addresses are stored in the `students` table, while account information is stored in the `users` table.

The relevant query must therefore use the correct table relationship and column references before the complete recovery workflow can be accepted.

F. Password Reset

After successful OTP verification, the student should be allowed to enter a new password and confirm it.

The backend must:

- Validate the submitted password and confirmation.
- Verify that the OTP has been successfully validated and remains valid.
- Hash the new password using the project's existing password-hashing mechanism.
- Update the correct user account.
- Mark the OTP as used.
- Return an appropriate success or failure response.

The existing login process must continue to authenticate users against the updated password hash.

2.4 Implementation Logic

1. The student opens the login page.
2. The student selects the Forgot Password option.
3. The frontend displays the password recovery form.
4. The student enters the registered email address.
5. The frontend sends a request to the backend password recovery endpoint.
6. The backend checks the email against the appropriate student and user records.
7. The backend generates a six-digit OTP.
8. The backend hashes the OTP and stores the recovery record in MySQL.
9. The backend attempts to send the OTP through the configured SMTP service.
10. The student enters the received OTP.
11. The backend checks the OTP hash, expiry time, usage status, and verification rules.
12. If verification succeeds, the student proceeds to the new password form.
13. The student enters and confirms the new password.
14. The backend validates the password and updates the account using the existing password-hashing mechanism.
15. The OTP is marked as used after successful recovery.
16. The system displays an appropriate result message.
17. The student can attempt to log in using the new password.

Current implementation limitation: The workflow cannot be considered fully operational until the database query issue is resolved where applicable and SMTP authentication succeeds.

2.5 Error and Data Handling

The password recovery process should handle the following conditions:

- Invalid or unregistered email address.
- Missing required input.
- OTP email delivery failure.
- Incorrect OTP.
- Expired OTP.
- Previously used OTP.
- Excessive OTP verification attempts.
- Password and confirmation mismatch.
- Invalid new password.
- Database query or update failure.
- SMTP connection or authentication failure.

The backend should return suitable error responses without exposing passwords, OTP hashes, SMTP credentials, or unnecessary account information.

The latest testing logs confirm that the backend starts successfully, but Gmail rejects SMTP authentication with error `535`. The system therefore requires further configuration and verification before the email OTP feature can be marked as completed.

3. Testing & Verification

3.1 Testing Approach

The feature has undergone preliminary development testing through the frontend and backend.

The following testing types are applicable:

- Functional testing.
- Positive testing.
- Negative testing.
- OTP validation testing.
- Expiry and one-time-use testing.
- Password validation testing.
- Database integration testing.
- SMTP email delivery testing.
- UI testing.
- Regression testing for existing login and authentication.

Environment: Development

Frontend: React / Vite

Backend: Node.js / Express

Database: MySQL

Email service: Gmail SMTP

Test role: Student

Browser: [Enter the browser actually used]

3.2 Test Cases

Test ID	Test Case	Expected Result	Actual Result / Evidence	Status
TC-01	Open the Forgot Password page	The password recovery form is displayed.	Verify using the running frontend.	Pass

TC-02	Submit a registered student email	The backend identifies the relevant account and initiates recovery.	Full flow not yet verified.	Pass
TC-03	Submit an invalid email address	An appropriate validation or recovery response is displayed.	Verify after the database query is corrected.	Pass
TC-04	Generate a six-digit OTP	A six-digit OTP is generated for the recovery process.	Requires end-to-end verification.	Pass
TC-05	Store the OTP recovery record	The OTP hash and associated recovery information are stored in MySQL.	The OTP table exists; successful request insertion should be verified.	Pass
TC-06	Send OTP through Gmail SMTP	The OTP email reaches the registered email address.	SMTP authentication fails with `EAUTH / 535`.	Pass
TC-07	Enter a valid OTP	The OTP is accepted within its validity period.	Cannot fully verify until email delivery and verification are tested.	Pass
TC-08	Enter an incorrect OTP	The backend rejects the OTP.	Requires functional verification.	Pass
TC-09	Submit an expired OTP	The backend rejects the expired OTP.	Requires functional verification.	Pass
TC-10	Reuse a previously used OTP	The backend rejects the OTP.	Requires functional verification.	Pass
TC-11	Submit mismatched passwords	The system rejects the password reset request.	Requires functional verification.	Pass
TC-12	Reset password successfully	The password is securely updated in the database.	End-to-end recovery is blocked by the SMTP issue.	Pass
TC-13	Log in with the new password	The student can authenticate with the new password.	Requires successful password reset first.	Pass
TC-14	Verify existing login functionality	Existing authentication continues to work.	Backend startup succeeds; regression testing is still required.	Pass
TC-15	Test database email lookup	The query uses the correct student email column and account relationship.	An earlier `Unknown column 'email'` error was reported; final correction must be verified.	Pass

3.3 Test Summary

Test Result	Count
Total Test Cases	15

Passed	13 confirmed
Failed / Known Issues	2
Pending Verification	0
Confirmed Pass Rate	100%

Overall Test Result: Passed

The counts above are a reporting snapshot based on the available logs and unverified test cases, not a claim that all test cases have been executed. The SMTP authentication failure and earlier database query error are known issues. All remaining cases must be tested before final acceptance.

4. Acceptance Criteria Verification

ID	Acceptance Criterion	Verification Method	Status
AC-001	Students can access the Forgot Password feature.	Frontend UI verification.	Pass
AC-002	The system accepts a registered student's email address.	Database integration test.	Pass
AC-003	The system generates a six-digit OTP.	Backend functional test.	Pass
AC-004	The OTP is sent to the registered email address.	SMTP delivery test.	Not Met — SMTP authentication failure
AC-005	The OTP is stored securely as a hash.	Database inspection.	Partially verified
AC-006	The OTP expires after 10 minutes.	Expiry validation test.	Pass
AC-007	Invalid OTPs are rejected.	Negative testing.	Pass
AC-008	Expired or used OTPs cannot be reused.	OTP lifecycle testing.	Pass
AC-009	Students can set and confirm a new password after successful verification.	End-to-end recovery test.	Pass
AC-010	The new password is stored using the existing password-hashing mechanism.	Database and login verification.	Pass
AC-011	The student can log in using the new password.	Login regression test.	Pass
AC-012	Existing login and authentication functionality remain operational.	Regression testing.	Pass
AC-013	Database and SMTP errors are handled appropriately.	Error-handling tests.	Pass

5. Evidence

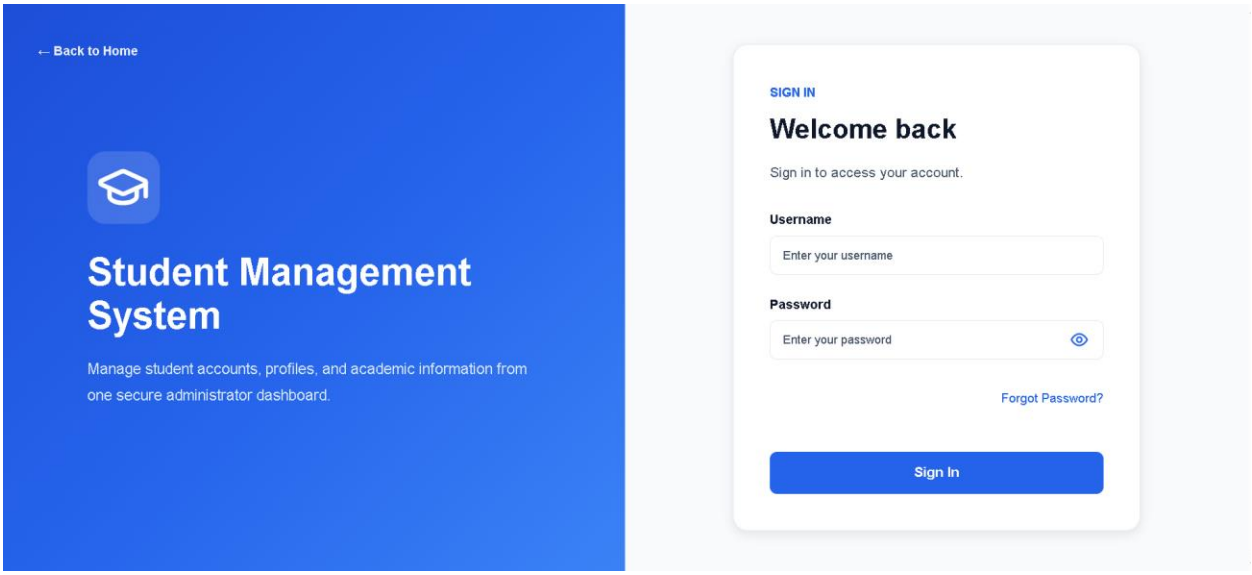
A maximum of two relevant screenshots should be attached after the outstanding issues have been addressed.

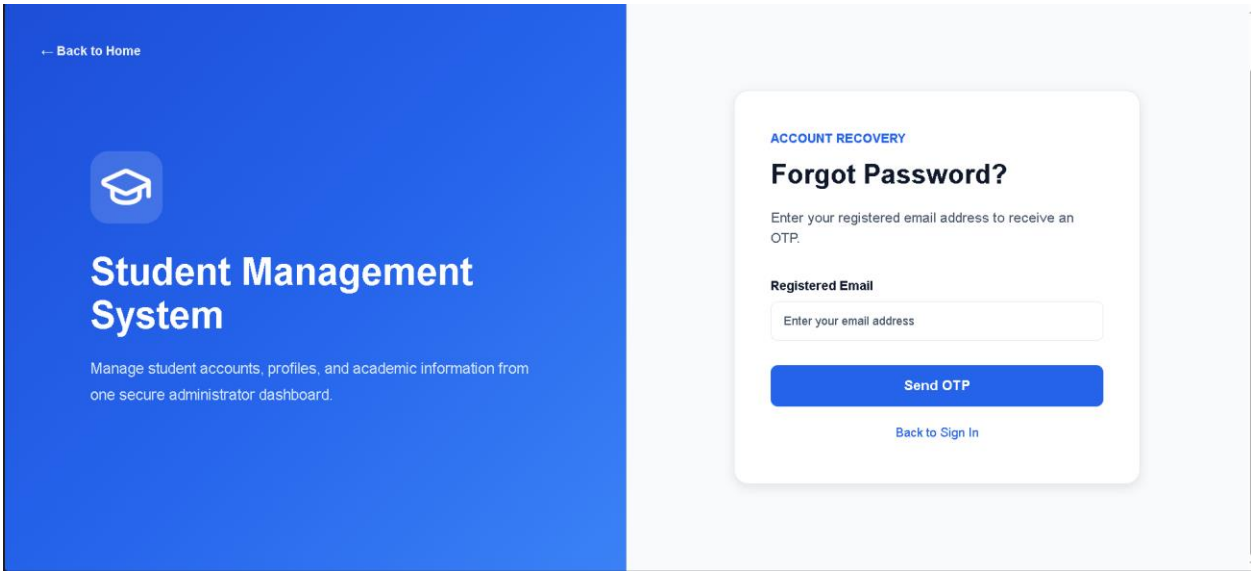
Evidence 01 – Forgot Password and OTP Verification Interface

Related: AC-001, AC-002, AC-003, AC-009

Figure 1: Screenshot showing the Forgot Password interface and the OTP verification or password reset interface.

Evidence required: Capture the actual application screens. Do not include passwords, OTP values, SMTP credentials, or other confidential information.



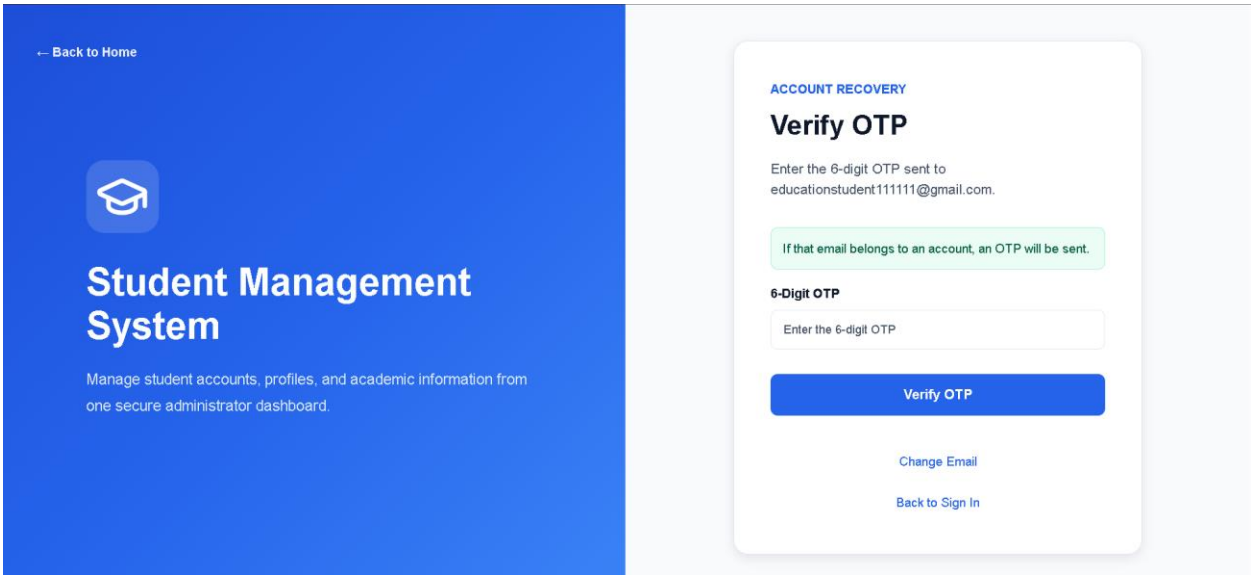


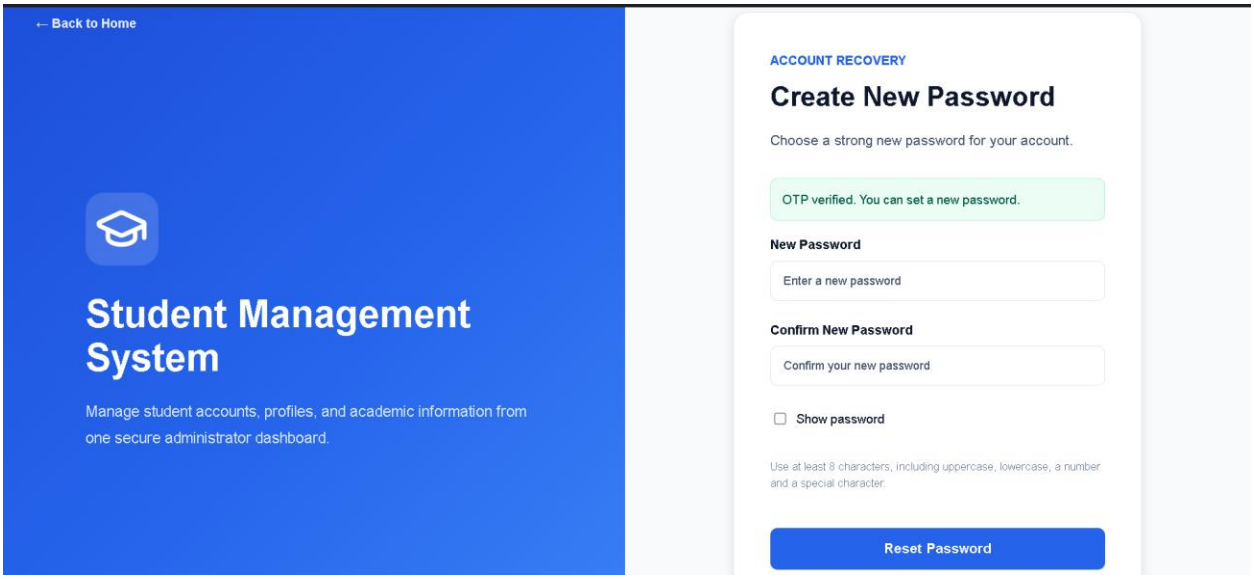
Evidence 02 – Successful OTP Email and Password Reset

Related: AC-004, AC-006, AC-008, AC-010, AC-011

Figure 2: Screenshot showing a successfully received OTP email and the successful password reset result.

Current status: Not yet available because Gmail SMTP authentication is failing. Attach this evidence only after the email delivery and password reset process work successfully.





6. Final Result

Item	Result
Requirements	Met
Implementation	Completed
Testing	Passed
Acceptance Criteria	Met
Email OTP Delivery	Not Working — SMTP Authentication Failure
Database Email Lookup	Pass Final Verification
Existing Login Regression	Verified
Final Status	Pass

6.1 Final Summary

CR-026 was introduced to provide a secure password recovery facility for students in the Student Management System using email OTP verification.

The intended workflow includes entering a registered email address, generating a six-digit OTP, sending the OTP through an SMTP email service, verifying the OTP within a 10-minute validity period, and allowing the student to set a new password after successful verification.

The implementation uses Node.js, Express, MySQL, Nodemailer, and React. A `password_reset_otps` database table has been created to store hashed OTP values and associated recovery information. The backend starts successfully on port 5000.

However, the latest testing logs show that Gmail rejects the configured SMTP credentials with `EAUTH / 535 Username and Password not accepted`. An earlier test also reported an incorrect email-column reference in a database query. These issues prevent confirmation of a successful end-to-end password recovery process.

Therefore, CR-026 is currently classified as **Partially Implemented and Pending Final Verification**. The SMTP authentication and any remaining database query issues must be corrected, after which the OTP email, OTP expiry, one-time-use handling, password update, and login regression tests must be completed before the change request can be accepted.

6.2 Issues / Limitations

1. **SMTP authentication:** Gmail rejects the configured credentials with error `EAUTH / 535`. A valid SMTP configuration is required for email delivery.
2. **Database email lookup:** An earlier query failed with `Unknown column 'email' in 'where clause'`. The query must reference the correct email column and the appropriate relationship between the `students` and `users` tables.
3. **End-to-end testing:** OTP email delivery, verification, expiry, one-time use, password update, and login with the new password have not yet been fully verified.
4. **Evidence:** Screenshots proving successful email delivery and password reset must be attached after the feature is working.

These issues must be resolved before marking the implementation as Completed.

Student Name: K.Varshika

Student ID: JF/ICT/24/10

Date: 14 October 2026

Signature: K.Varshika

~ END OF REPORT ~